Grupo Bimbo, S.A.B. de C.V. | ESG Scores Raw Data

BMV:BIMBO A (MI KEY: 4276592; SPCIQ KEY: 877936; TCUID: 53231)

Public

Year: Methodology Year: 2025
Question: Risk Management Processes
Include Modeled Scores : Yes

Risk Management Processes

Question

Does the company have risk management processes to promote effective risk culture?

Rationale

This question assesses a company's risk management practices and strategies, essential for fostering an effective risk culture. Effective risk and crisis management are vital for long-term financial stability and adaptability. Implementing internal control processes ensures compliance with current regulations and positions a company to proactively refine these controls.

Conducting robust risk assessments including evaluating risk exposure and determining risk appetite allow companies to respond strategically to events that may have a material impact. Moreover, regular and frequent risk reviews and audits can enhance the effectiveness of risk management processes. To embed these practices into the wider organization, measures should be taken to educate and incentivize employees at all levels of the business, thereby nurturing a strong and effective risk culture. Such an approach ensures risk management is not just a compliance exercise but a fundamental part of the company's operational mindset.

Performance Summary	
Question Level Company Performance	53
Question Weight	42
Year-on-Year Change	0
Industry Average Score	20
Industry Highest Score	100

The question layout and the company's verified information is provided below. No information is shown if the company did not provide any information or if it opted out of sharing non-public information.

Additional Question Guidance & Information Display

Key Definitions

Risk review: A risk review is a process that involves identifying risks and assessing or reassessing their impact and likelihood. This process includes updating the status of various risks and implementing procedures to identify hazards and determine potential negative effects. This may include stress testing and sensitivity scenario analyses. We expect risk exposure to be reported for at least two of the identified risks.

The elements that define a risk review and are considered best practice include:

1. Description of company-specific risk exposure: This should at least evaluate the potential magnitude and likelihood of materialization of the risk, considering the factors unique to the business or industry to define the impact of the risk on the company, e.g., stress testing, scenario analysis and sensitivity analysis are measures to assess the magnitude of impact when risks materialize but do not necessarily give an indication of likelihood of materialization.

2. Process or framework to determine risk appetite: There should be a clearly defined process or framework outlining the company's risk appetite (the level of risk it is willing to accept) for the identified risks including who within the organization is responsible for this.

3. Description of mitigating actions: Actions taken to reduce the severity of the risk and the likelihood of potential negative impacts should be described.

Review of risk exposure: Regular reviews are essential to keep up with changes in the risk landscape that could affect the company's risk exposure. These reviews help the organization to stay resilient against potential risks. They ensure the designated risk appetite and mitigating actions stay up-to-date and relevant. The mere reporting of risk exposure indicators, e.g., in the annual report is not considered sufficient evidence of an active risk exposure review process.

Audit of risk management processes in the last two years: This involves a systematic assessment of the methods, tools and processes used in identifying, evaluating, controlling, monitoring and reporting risks. Per best practice, audits can be conducted by qualified, internal auditors and by qualified, independent third-party auditors. These audits should follow guidelines on management systems audits or risk management standards such as ISO 31000 and should be conducted at least every two years. Audits related to internal controls of financial reporting and statements of commitment are not considered sufficient here. The frequency of audits should be clearly reported.

Promotion of an effective risk culture: Creating a strong risk culture is important for integrating risk processes, procedures and employee awareness throughout the organization. This can be achieved by:

- **Regular risk management education for non-executive directors:** Education of board members should be recurring and specific to risk management. This is different from regular risk reporting to the board.
- **Providing training to all employees:** Training must cover risk management and be provided at a group level.
- **Considering risk factors when developing new products or services:** Risk criteria can be linked to financial risks, regulatory risks, operational risks, etc.
- **Offering financial incentives tied to meeting risk-related goals:** Incentives should be related to specific risks the company has identified as key concerns. For instance, if health and safety or governance are noted as primary risks, incentives could be connected to these areas.

Data Requirements

To answer this question, it is important to focus on the organization's general approach to risk identification and risk review, rather than specific areas such as occupational health & safety, human rights or, climate change. Reports such as those from the Task Force on Climate-related Financial Disclosures (TCFD) or the Carbon Disclosure Project (CDP) are not considered suitable evidence in this context. However, if climate change is identified as a significant material risk, we would expect it to be reported in the overarching risk section.

Risk Review

- Please provide information that the evaluation considers multiple factors like likelihood, magnitude, business relevance, geographical location, etc., to distinguish between a mere description of the risk and an assessment of its exposure.
- Company risk exposure description without any information nearby which explains how the company evaluates the impact is not accepted.

Risk Culture

Not acceptable for 'board of directors training on how to manage risks':

- Directors' induction or orientation programs that cover risk management, as these are typically one-off events rather than ongoing education.
- Training that is solely about specific topics, such as new regulations or policies.
- Trainings only provided to selected directors implying not all non-executive directors receive these trainings.
- If non-executive directors are "encouraged" or "guided" or "recommended" to take training. Instead, please provide information that a specific evidence that education is provided or mandated.
- The board receiving briefings or reports from committees.
- If the board is updated on internal risk management matters as this is a mere reporting on risk management performance to the board of directors and is not equivalent to a formal training or education.

Not acceptable for 'focused training throughout the organization on risk management principles':

- Information for trainings which are focused on specific topics such as new regulations, policies, health and safety, or cybersecurity are not accepted as these are considered trainings on specific risks, not overall risk management.

Disclosure Requirements

The document(s) you have attached will be used to verify your response. Any response that cannot be verified in the attached document(s) will not be accepted.

Listed and/or publicly owned companies are required to provide links to public reports or corporate websites.

Non-listed companies are required to provide the following evidence, depending on the type of company:

- **Family-owned companies and privately owned companies** are required to provide public reports, corporate websites, or internal documents.
- **Cooperatives** are required to provide public reports, corporate websites, or internal documents.
- **State-owned companies** are required to report on their corporate governance in the public domain as their key stakeholder is the general public.

Please note: Answers in the form of "Confidential additional comments" for any type of non-listed company will not be accepted.

References

COSO Framework

ISO 31000:2018 Risk Management

Standards & Frameworks

CSRD - GOV-1 Governance Bodies Role, GOV-2 Board Sustainability Oversight, IRO-1 Materiality Assessment Process, IRO-1 Risks & Opportunities Assessment Process, SBM-3 Material Impacts Risks & Opportunities, SBM-3 Material Risks & Opportunities

TNFD - Governance A, Risk Management A (i), Risk Management A (ii), Risk Management B, Strategy C

Data View

QUESTION LEVEL INPUT	COMPANY ANSWER
Company reports its risk management processes and strategies for effective risk culture	Applicable
The company reports on the description of specific risk exposure (considering?likelihood and magnitude)?of at least 2 identified risks.	YES
The company reports on its process or framework to determine the risk appetite for identified risks	YES
The company provides mitigating actions for at least two risks identified	YES
The company conducts an internal audit of its risk management process	-
The company conducts an external audit of its risk management process	-
The company reports on its review frequency of risk exposure.	Twice a year or more
The company promotes an effective risk culture by incorporating financial incentives for risk management metrics.	-
The company promotes an effective risk culture through focused training on risk management principles.	-
The company promotes an effective risk culture through risk management education for non-executive directors.	-
The company promotes an effective risk culture by incorporating risk criteria in the development of products and services.	YES

Questionnaire

Does the company have risk management processes and strategies to promote an effective risk culture?

Listed companies are required to provide links to public reports or corporate websites.

Non-listed companies are required to provide internal documents and/or links to public reports or corporate websites.

1. (•) Yes, the company has risk management processes and strategies to promote an effective risk culture.

Grupo Bimbo, S.A.B. de C.V. | ESG Scores Raw Data

Risk Review

Aspects of our risk review process include the following:

1. [x] Description of the company-specific risk exposure (considering likelihood and magnitude) of at least two identified risks
2. [x] Description of process or framework to determine the risk appetite for identified risks
3. [x] Description of mitigating actions for at least two identified risks

Risk Exposure

We review our company's risk exposure on a regular basis. Please attach evidence of the frequency of the assessments:

1. (•) At least twice a year or more frequently
2. ( ) At least yearly
3. ( ) Less frequently than yearly
4. ( ) Not specified

Risk Management Process Audit

We have conducted an audit of the risk management process. Please specify if an internal audit and/or an external audit has been performed:

1. [ ] Yes, we have conducted an internal audit in the last two years
2. [ ] Yes, we have conducted an external audit in the last two years

Risk Culture

We have strategies in place to promote an effective risk culture throughout the organisation:

1. [ ] Regular risk management education for all non-executive directors
2. [ ] Focused training throughout the organization on risk management principles
3. [x] Incorporation of risk criteria in the development of products and services
4. [ ] Financial incentives which incorporate risk management metrics

2. ( ) No, the company does not publicly report on risk management processes and strategies.
3. ( ) Not applicable. Please provide explanations in the comment box below.
4. ( ) Not known

Confidential additional comments

Use the text field below only in the following cases: (i) to describe significant changes in data or calculation methodology compared to last year's submission, (ii) to explain why a question is not applicable to your company's business model, (iii) to explain if your data deviates from the unit or format requested, or (iv) to provide supporting notes on translations of non-English references.